



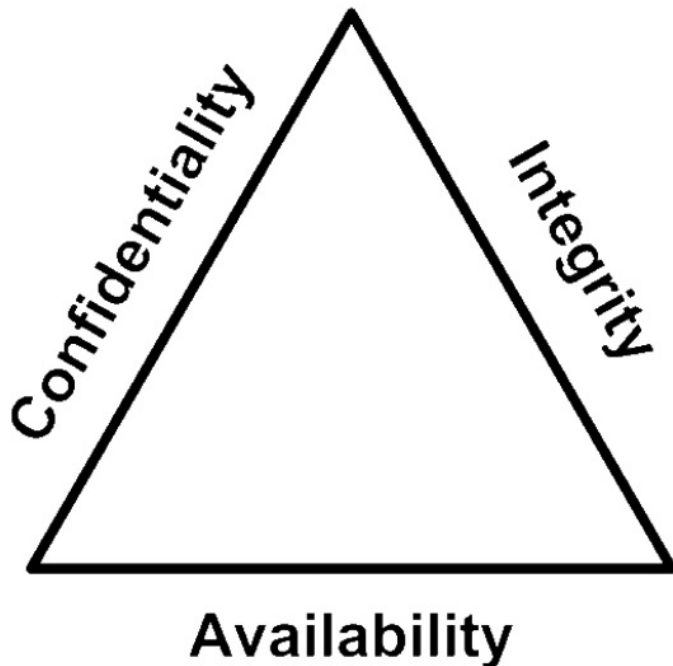
Seguridad en Redes de Cómputo

**Unidad 1. Conceptos Básicos de
Seguridad**

MRT. Martha Elizabet Domínguez Bárcenas

Conceptos básicos de seguridad

- En el contexto actual, los **sistemas de información** sostienen la forma en que la mayoría de las organizaciones hacen negocios.
- **Información.** Incluye datos, conocimiento, propiedad intelectual, etc., que son importantes para una **organización**.
- Es importante para las organizaciones, cuidar la **seguridad de la información**



Seguridad de la información

- Seguridad. Estado de protección.
- La información puede protegerse de varias maneras. La forma más común es considerando la **Triada CIA**
 - **Confidencialidad.** Mantener la información secreta, asegurándose de que solo puedan verla los autorizados
 - **Integridad.** Asegurarse de que la información no haya sido modificada sin autorización.
 - **Disponibilidad.** Asegurarse de que los autorizados tengan acceso a la información en todo momento
- Otra característica de la Seguridad
 - **No repudio.** Capacidad de demostrar el origen de la creación o modificación de cierta información

Seguridad de la información

Riesgo

Amenaza

Vulnerabilidad

Riesgo

- “Potencial de pérdida, medido a través del **impacto** y la **probabilidad** de que una **amenaza** aproveche una **vulnerabilidad** en uno o más **activos** de un sistema de información” (MacMillan, 2021).

$$\text{Riesgo} = \text{Impacto} + \text{Probabilidad}$$

- **Activo.** Algo de valor para la organización
 - Sistemas de información (servidores, software, terminales de pago, routers, laptops)
 - Información (conjuntos de datos, imágenes, planos, fórmulas, propiedad intelectual)
 - Las organizaciones tienen muchos activos: **digitales**, **físicos** e incluso, **reputacionales**.
 - **Diferentes activos** tienen **diferentes riesgos** asociados con ellos
 - **Diferentes amenazas**, **diferentes vulnerabilidades** y **diferentes niveles de impacto** en caso de pérdida, exposición o modificación de dicho activo

Amenaza

- Peligro potencial para los activos, los datos o la red de una organización
- Incluyen un **Actor de amenaza** o perpetrador de hechos que representan la amenaza
 - Hackers maliciosos que quieren acceder a registros de la organización
 - Empleado deshonesto que quiere vender secretos a la competencia
 - Empleado que abre un archivo liberando un ransomware en la red de la organización.
- Cada actor de amenaza puede tener **diferentes metas y habilidades**
- **Diferentes métodos** implican **diferentes probabilidades y diferentes controles de mitigación**
- Los actores de amenazas se pueden clasificar en: **agentes maliciosos internos, agentes maliciosos externos, internos e internos accidentales.**
 - Ejemplo: maliciosos externos. Se pueden dividir aún más:
 - Actores únicos con mucha o poca experiencia (script kiddies)
 - Grupos de actores distribuidos en equipos, con financiamiento, pueden incluir hacktivistas, organizaciones criminales o incluso a la competencia
 - Actores patrocinados por el estado que cuentan con tiempo, recursos y herramientas, con intereses específicos

Vulnerabilidad

- No se puede tener un riesgo sin una vulnerabilidad
- Es la **debilidad de un activo** (en un sistema o en su diseño) que puede ser explotada por una amenaza
- Pueden ser varias por categoría de activo.
- Ejemplos:
 - Activos de Hardware: sobre calentamiento y desgaste
 - Activos de Software: código defectuoso

Gestión del riesgo

- Procesos para **minimizar el potencial de pérdida**
- Implica identificar, evaluar, priorizar riesgos y aplicar **medidas de control**.
- Proporciona transparencia y contabilidad de las operaciones diarias en una organización, **alineando los riesgos con los objetivos estratégicos**.
- Ayuda a la organización a **prepararse para eventos adversos** que podrían impactarle negativamente (prevención)
- En la actualidad una gran parte del enfoque de las organizaciones en sobre la gestión de riesgos es sobre los **sistemas de información**.

Tratamiento del riesgo

- **Forma de control** seleccionada para modificar el nivel de riesgo.
 - **Evitar el riesgo.** Evitar la probabilidad del riesgo por completo. Implica no realizar alguna acción que conduzca a él.
 - **Reducir el riesgo.** Reducir los niveles de impacto o de probabilidad, a través de controles de mitigación
 - **Transferir el riesgo.** Transferir todo o parte del riesgo a una tercera parte, por ejemplo, a través de outsourcing y seguros.
 - **Aceptar el riesgo.** Cuando la organización reconoce que un riesgo no requiere más mitigación o que no es viable mitigar más el riesgo
- **Controles de mitigación.** Métodos por los cuales se intenta proteger cada activo de amenazas (contra-medida que reduce la probabilidad o la gravedad de una amenaza o riesgo)
 - **Riesgo residual.** Nivel de riesgo después de aplicar el control de mitigación. Generalmente se vuelve un riesgo aceptable

Regulaciones legales y estructuras de cumplimiento (1/2)

- Los requisitos de la organización podrían proceder de **autoridades gubernamentales o de organismos de certificación**.
 - Por ejemplo: las normativas y leyes de privacidad sobre el tratamiento de datos personales.
 - El Reglamento General de Protección de Datos (GDPR)
 - La Ley de Protección de la Privacidad Infantil en Internet (COPPA) (EU)
 - La Ley de Portabilidad y Responsabilidad del Seguro Médico (HIPAA)
 - La Ley de Privacidad del Consumidor en California (CCPA)
 - Todas las anteriores representan **obligaciones legales** y el **no cumplir** con sus requerimientos podría tener **repercusiones económicas o reputacionales**.
 - La mayoría de las regulaciones sobre privacidad se enfocan en la **transparencia durante el procesamiento de información personal identificable (PII) o información de salud protegida (PHI)**
 - La mayoría requiere que se de la **posibilidad de revisar y revocar el acceso, de saber cómo, dónde y quién está procesando la información**.

Regulaciones legales y estructuras de cumplimiento (2/2)

- También hay **estándares** como los de la Organización Internacional para la Estandarización (ISO)
 - **ISO 27001**. Altamente mencionado y enfocado en la gestión de la seguridad de la información.
 - **ISO 27018**. Proporciona un código de prácticas para la seguridad en la nube
- Las organizaciones que cumplen con los requisitos establecidos en la norma están listas para ser **auditadas por terceros y obtener certificaciones o acreditaciones** al respecto.
- **Importancia de una certificación**
 - Altamente **valoradas por los clientes** (potenciales y existentes) y empresas asociadas
 - **Evidencia** de que se ha alcanzado el nivel mínimo de seguridad en la organización
 - Las **regulaciones están en constante evolución**, por lo que la organización debe estar al pendiente de ello.

Estrategia de seguridad de la información (1/2)

- Las organizaciones requieren de **programas de seguridad de la información, documentados y actualizados regularmente** (la periodicidad dependerá de la norma a seguir)
- Los equipos de seguridad de la información deben identificar y entender los **frameworks, estándares, regulaciones y leyes que aplican a dicha organización**, para evitar multas y sanciones, así como para tener una buena base contra los riesgos de seguridad de la información.
- Las organizaciones pueden **apoyarse en software y sistemas de información para garantizar que sus empleados cumplan tanto la ley como los protocolos** diseñados por los altos ejecutivos en las políticas definidas
 - Herramientas que proporcionan **pseudonimización**
 - Herramientas de **eDiscovery** o descubrimiento electrónico. Proceso para identificar, preservar, recopilar, revisar y entregar información que puede utilizarse como prueba legal (buzones de correo, grupos compartidos, chats, unidades compartidas o discos duros) - cumplimiento legal-
- Una parte importante de la mayoría de las normas de seguridad es el principio de **Mejora continua**
 - Revisión y monitoreo y mejora constante (gradual)

Estrategia de seguridad de la información (2/2)

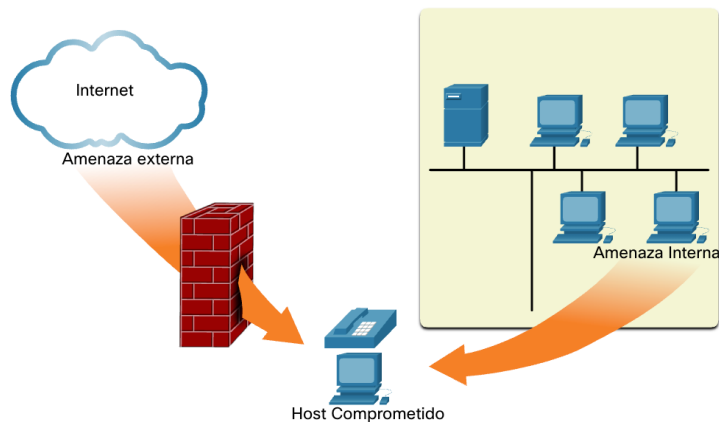
- Debe incluir:
 - Creación de **políticas, procedimientos y manuales** de seguridad de la información
 - Establecimiento y mantenimiento de un programa de **concientización**
 - Gestión de riesgos por parte de **terceros** (servicios en la nube: SLA)
 - Presentación de **informes y mejora continua**
 - Captar la atención de todas las partes interesadas
 - Resaltar la relación costo-beneficio de la estrategia de seguridad de la información



Seguridad en redes de cómputo

Vector de ataque

- Ruta por la que un actor de amenaza puede obtener acceso a un recurso en la red.
 - Se originan dentro y fuera de la red corporativa



- Ataque de DoS
- Robo o copia de datos confidenciales
- Desconexión de la red crítica
- Conexión de una unidad USB infectada
- Infección por malware

Ataques de red habituales (1/2)

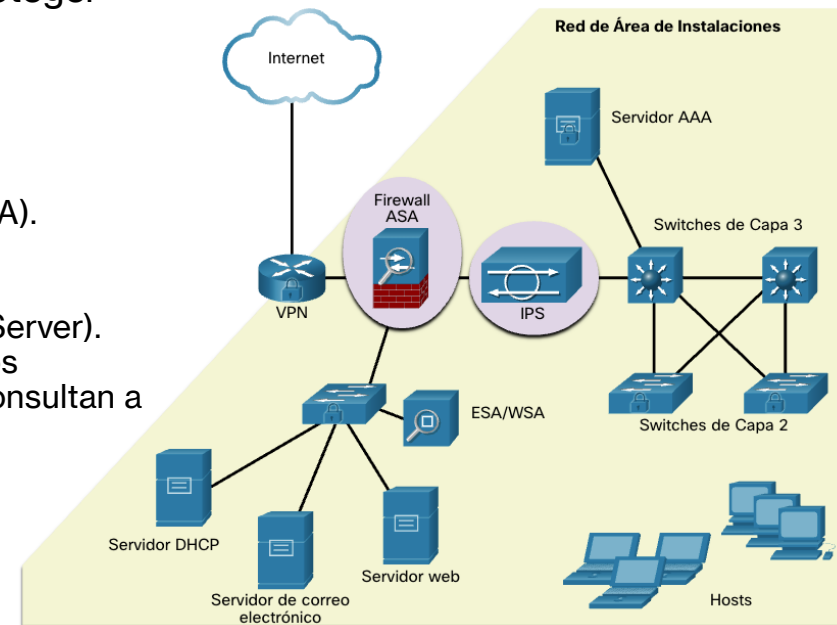
- **Ataques de reconocimiento.** Para realizar detección y análisis no autorizado de sistemas, servicios o vulnerabilidades
 - Consulta de información pública sobre el objetivo
 - Barrido de ping de la red destino. Para detectar direcciones IP activas
 - Análisis de puertos de las direcciones IP activas
 - Escaneo de vulnerabilidades. Consulta de puertos identificados para determinar tipo y versión de la aplicación y S.O. que ejecuta el host.
 - Ejecución de herramientas de ataque. Para explotación de vulnerabilidades
- **Ataques de Acceso.** Aprovechan vulnerabilidades conocidas en servicios de autenticación (p.e. FTP, Web) para obtener acceso y escalar privilegios
 - Ataques de contraseña. Utilizando una variedad de herramientas para desifrarlas
 - Ataques de suplantación de identidad. El dispositivo del actor de amenaza intenta hacerse pasar por otro dispositivo falsificando datos: suplantación de IP, de MAC, de DHCP
 - Redireccionamiento de puertos
 - Ataque de Man-in-the-middle
 - Ataque de desbordamiento de buffer (DoS)

Ataques de red habituales (2/2)

- **Ingeniería Social.** Manipulación de las personas para que realicen acciones o divulguen información.
 - Pretexting
 - Phishing y todas sus variantes
 - Quid pro quo
 - Baiting o carnada
 - Tailgating
 - Shoulder surfing
 - Dumpster diving o Trashing
- Ataques de DoS y DDoS. Crean algún tipo de interrupción de los servicios de red para usuarios, dispositivos o aplicaciones
 - Sobrecarga de tráfico
 - Paquetes maliciosos formateados. El receptor es incapaz de manejarlo, generando retrasos o incluso la detención del servicio.

Mejores prácticas de Seguridad en Redes

- Enfoque de defensa en profundidad (o en capas)
 - Combinación de dispositivos y servicios que trabajen en conjunto
 - Proteger los dispositivos (routers, switches, servidores, host)
 - Uso de varios dispositivos y servicios de seguridad para proteger los activos
 - Redes Privadas Virtuales (VPN)
 - Firewall
 - Sistema de Detección/Prevención de Intrusiones (IDPS)
 - Email Security Appliance (ESA) /Web Security Appliance (WSA). Filtración de spam y correos sospechosos / sitios de malware conocidos y sospechosos
 - Servidor de Autenticación, Autorización y Contabilidad (AAA Server). Contiene una BD segura de la gente autorizada a acceder a los dispositivos de red y administrarlos. Los dispositivos de red consultan a esta BD para autenticar a los usuarios



Referencias

- MacMillan, J. (2021). *Infosec Strategies and Best Practices: Gain Proficiency in Information Security Using Expert-Level Strategies and Best Practices*. Packt Publishing.
- Cisco Networking Academy (s.f.). *CCNA: Redes empresariales, seguridad y automatización*. [Curso en línea].
<https://www.netacad.com>